SIMATS ENGINEERING
ASSESSMENT TOOL 1

COURSE NAME: Ethical Hacking **COURSE CODE: ITA14**

COURSE OUTCOME COVERED

CO2: Execute footprinting in social engineering such as DNS analysis, competitive intelligence gathering, and attack simulations to collect relevant information for identifying potential security risks.

Assessment Tool Weightage: 30%

Duration: 90 min **Total Marks: 50**

Report Analysis
Questions

1. A security analyst performed a network scan on the target 192.168.1.10 using the Nmap tool. The report identified several open ports, including HTTP (80), SSH (22), and MySQL (3306), along with the operating system and service versions. Analyze the report and explain the security risks associated with the identified services. Discuss how an attacker could exploit these services and recommend suitable security measures to protect the target system. **(20 Marks)**

2. A phishing awareness campaign was conducted for employees of ABC Technologies Pvt. Ltd. using the GoPhish tool. The report indicates that 40% of employees clicked the phishing link, 20% entered their login credentials, and several users downloaded a malicious attachment. Analyze the report and identify the security weaknesses demonstrated by the employees. Recommend suitable user awareness programs, email security controls, and organizational policies to reduce the risk of successful social engineering attacks.(**20 Mark).**

3. A DNS assessment report generated using the Dig tool shows that the organization's DNS server permits a successful DNS Zone Transfer (AXFR), exposing internal hostnames, mail servers, and DNS records. Analyze the report and explain the security implications of the exposed information. Discuss how attackers could exploit these findings and recommend best practices to secure the DNS infrastructure..**(10 Marks)**

Code of Conduct:

I Dinesh R-192421117 certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.
I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: R Dinesh

RUBRICS FOR CALCULATION

Report Analysis

Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Report Analysis and Interpretation	25%	Accurately interprets the security report, identifies all key findings, and explains their significance with excellent technical understanding.	Correctly interprets most findings with minor omissions or inaccuracies.	Identifies only some findings and provides limited interpretation.	Unable to interpret the report or identify key findings.
Identification of Security Risks and Vulnerabilities	25%	Correctly identifies all security risks, vulnerabilities, and possible attack vectors with clear technical justification.	Identifies most risks and vulnerabilities with minor errors.	Identifies only a few risks with limited technical explanation.	Fails to identify major risks or vulnerabilities.
Application of Cybersecurity Concepts and Countermeasures	30%	Applies appropriate ethical hacking concepts and recommends comprehensive, practical, and technically sound countermeasures.	Recommends suitable countermeasures with minor technical gaps.	Provides limited or partially appropriate recommendations.	Recommendations are inappropriate, incomplete, or missing.
Technical Communication and Documentation	20%	Response is well-organized, technically accurate, clearly presented, and uses appropriate cybersecurity terminology throughout.	Response is organized and understandable with minor documentation or presentation issues.	Response lacks clarity, organization, or contains several technical inaccuracies.	Response is poorly organized, incomplete, and difficult to understand.

1)

1. Introduction

Nmap (Network Mapper) is a network scanning tool used to identify open ports, running services, operating systems, and service versions on a target system. In this report, the target IP address is 192.168.1.10. The scan identifies HTTP (port 80), SSH (port 22), and MySQL (port 3306) as open ports. These findings help administrators identify possible security vulnerabilities and protect the system from attacks.

2. Analysis of Open Ports and Security Risks

a) HTTP – Port 80

HTTP is used to transfer web pages between a web server and a client. It does not encrypt communication by default.

- Security risks: Login credentials and sensitive information may be exposed if transmitted over HTTP. Vulnerable web applications may also contain SQL injection, cross-site scripting (XSS), or other security flaws.
- Possible exploitation: An attacker may intercept unencrypted traffic or exploit vulnerabilities in the web application to access sensitive information or manipulate data.
- Security measures: Enable HTTPS using TLS certificates, update the web server and application, validate user inputs, and deploy a web application firewall (WAF) where appropriate.

b) SSH – Port 22

SSH (Secure Shell) provides encrypted remote access to a system and is commonly used for server administration.

- Security risks: Weak passwords, outdated SSH software, and insecure configuration may allow unauthorized access.
- Possible exploitation: An attacker may attempt password guessing or brute-force attacks against SSH accounts, or exploit a known vulnerability in an outdated service.
- Security measures: Use SSH key-based authentication, disable direct root login, enforce strong authentication, restrict access to trusted IP addresses, and keep SSH software updated.

c) MySQL – Port 3306

MySQL is a database management system used to store and retrieve application data.

- Security risks: If the database is accessible to unauthorized users, sensitive information may be exposed, modified, or deleted. Weak database credentials and excessive privileges increase the risk.
- Possible exploitation: An attacker may attempt to guess database passwords, exploit a vulnerable MySQL version, or use compromised credentials to access confidential records.
- Security measures: Restrict MySQL access to trusted application servers, use strong passwords, apply least-privilege permissions, update MySQL regularly, and enable secure database connections when required.

3. Risks of Operating System and Service Version Disclosure

The Nmap report also identifies the operating system and service versions. This information helps administrators understand their network environment, but attackers can use it to identify outdated software and search for known vulnerabilities.

Countermeasures:

- Install security patches and updates regularly.
- Remove unnecessary services and close unused ports.
- Use firewalls to control incoming and outgoing traffic.
- Monitor logs and conduct regular vulnerability assessments.
- Follow the principle of least privilege.

4. Conclusion

The Nmap report identifies possible entry points through HTTP, SSH, and MySQL. Open ports do not automatically indicate vulnerabilities, but insecure configurations and outdated services can create serious risks. By applying patches, restricting access, encrypting communications, and monitoring network activity, the organization can significantly improve the security of the target system.

---

2)

1. Introduction

Phishing is a type of social engineering attack in which attackers send fraudulent emails or messages to trick users into revealing sensitive information, clicking malicious links, or downloading harmful attachments. GoPhish is a phishing simulation tool used by organizations to conduct authorized awareness campaigns and evaluate employee responses.

In this report, 40% of employees clicked the phishing link, 20% entered their login credentials, and several employees downloaded malicious attachments. These results indicate weaknesses in phishing awareness and email security.

2. Analysis of the Report

a) Employees clicking phishing links – 40%

A high percentage of employees clicked the phishing link, indicating that they may not carefully verify email senders or inspect suspicious URLs.

- Security weakness: Poor awareness of phishing indicators and suspicious links.
- Risk: Employees may visit fraudulent websites or expose their systems to malicious content.
- Solution: Train employees to verify senders, inspect URLs, and avoid clicking unexpected links.

b) Employees entering login credentials – 20%

Some employees entered their usernames and passwords on a simulated phishing page.

- Security weakness: Failure to recognize fake login pages and verify website authenticity.
- Risk: Attackers could steal credentials and gain unauthorized access to organizational accounts.
- Solution: Implement multi-factor authentication (MFA), password managers, and regular phishing awareness training.

c) Downloading malicious attachments

Several employees downloaded potentially malicious attachments.

- Security weakness: Employees did not adequately verify attachments before downloading them.
- Risk: Malicious files may install malware, steal data, or allow unauthorized access to company systems.
- Solution: Use attachment scanning, sandboxing, endpoint protection, and safe file-handling procedures.

3. Recommended User Awareness Programs

The organization should conduct the following awareness activities:

1. Regular training: Explain phishing, spoofed emails, fake websites, and social engineering techniques.
2. Simulated phishing campaigns: Use GoPhish periodically to measure employee awareness and identify areas needing improvement.
3. Practical demonstrations: Teach employees how to identify suspicious senders, links, attachments, and urgent requests.
4. Reporting procedures: Encourage employees to report suspicious emails immediately without fear of punishment for honest mistakes.
5. Continuous evaluation: Review campaign results and provide additional training to employees who need it.

4. Email Security Controls

ABC Technologies should implement these technical controls:

- Email filtering: Use secure email gateways to detect and block spam and phishing messages.
- SPF, DKIM, and DMARC: Configure these email authentication mechanisms to reduce email spoofing.
- Attachment scanning: Scan attachments for malware and use sandboxing for suspicious files.
- URL protection: Detect malicious links and block access to known phishing websites.
- Endpoint protection: Use updated antivirus and endpoint detection tools to identify malicious activity.
- Multi-factor authentication: Require an additional authentication factor to reduce the impact of stolen passwords.

5. Organizational Policies

The organization should establish clear security policies:

- Develop an email and internet usage policy.
- Require employees to report suspected phishing attacks promptly.
- Enforce strong password and MFA policies.

- Restrict access to confidential information according to job responsibilities.
- Establish an incident response procedure for compromised accounts and infected devices.
- Review phishing simulation results and update security training regularly.

6. Conclusion

The GoPhish report shows that employees are vulnerable to phishing attacks, particularly through suspicious links, credential theft, and malicious attachments. A combination of employee awareness training, secure email controls, MFA, and clear organizational policies can reduce these risks. Regular phishing simulations will help ABC Technologies measure improvements and strengthen its overall security posture.

---

3)

1. Introduction

The Domain Name System (DNS) translates domain names into IP addresses and helps users access network services. The dig tool is used to query DNS servers and examine DNS records. A DNS zone transfer (AXFR) allows DNS records to be copied from one DNS server to another, usually between authorized primary and secondary servers.

In this assessment, the DNS server permits a successful AXFR request, exposing internal hostnames, mail servers, and other DNS records. If the transfer is available to unauthorized users, it creates a security risk.

2. Security Implications of DNS Zone Transfer

a) Exposure of internal hostnames

Internal hostnames may reveal the names and purposes of servers, such as database servers, application servers, and administrative systems.

Risk: Attackers can use this information to identify valuable targets and plan further attacks.

b) Exposure of mail servers

DNS records may identify mail servers and related services.

Risk: Attackers can use this information to plan targeted phishing campaigns, email spoofing attempts, or attacks against exposed mail services.

c) Exposure of DNS records

A zone transfer may disclose records such as A, AAAA, MX, CNAME, and TXT records.

Risk: These records can reveal network structure, service locations, and information about the organization's infrastructure, making reconnaissance easier.

3. How Attackers Could Exploit These Findings

Attackers could use the exposed DNS information to:

1. Identify important servers and services.
2. Discover internal naming patterns and potential targets.
3. Perform further reconnaissance against identified systems.
4. Develop targeted phishing campaigns using organizational information.
5. Search for exposed or vulnerable services associated with the discovered hostnames.

The information does not automatically provide access to the systems, but it can help attackers plan more effective attacks.

4. Best Practices to Secure DNS Infrastructure

a) Restrict zone transfers: Configure DNS servers to allow AXFR requests only from authorized secondary DNS servers.

b) Use access control lists (ACLs): Permit zone transfers only from trusted IP addresses.

c) Configure DNS securely: Disable unnecessary services and remove unused DNS records that disclose sensitive information.

d) Apply regular updates: Keep DNS server software updated to fix known security vulnerabilities.

e) Monitor DNS activity: Review DNS logs and alert administrators to unauthorized or unusual zone transfer requests.

f) Separate internal and external DNS: Use split-horizon DNS where appropriate to prevent internal DNS information from being exposed publicly.

g) Conduct regular audits: Periodically test DNS configurations and verify that unauthorized zone transfers are rejected.

5. Conclusion

The successful DNS zone transfer indicates that the organization's DNS server may be incorrectly configured. Exposed hostnames, mail servers, and DNS records can help attackers perform reconnaissance and identify potential targets. Restricting AXFR to authorized servers, monitoring DNS activity, and conducting regular security audits will help protect the organization's DNS infrastructure